

שיעור תרגול - אתיאוריה לפרקטיקה

עו"ד תני שפירא, MyEDPO
DPO, CHPSE



קורס CISO55: מועדים

פרטיות בישראל	19.11
פרטיות בישראל	23.11
תרגול ותפקיד ה-DPO [תני]	26.11
תרגול קייסים [תני]	30.11
אכיפה בישראל + פרטיות בארה"ב [מרצים אורחים]	3.12
GDPR [ליאת]	7.12
GDPR [ליאת]	10.12
מועד אחרון להגשת סקר פרטיות	18.1
הצגת פרויקטים למנהלים	4.2

תוכן עניינים

- ✓ תרגול חוק הגנת הפרטיות
- ✓ דוגמה לעבודה
- ✓ תפקיד ה-DPO ומקומו בארגון
- ✓ שאלות



בואו נדבר תכל'ס...



zoominfo

מיהו הארגון הנסקר?

- במה עוסק הארגון?
- איפה הארגון ממוקם, כמה שנים קיים?
- מה תרבות הציות בארגון?
- האם הארגון מוסמך PCI/SOC/ISO?
- איזה כללים מיוחדים חלים על הארגון?
- מי הלקוחות (B2G/B2B2C/B2C/B2B, ישראל או חו"ל)?

איזה מאגרי מידע קיימים?

- לקוחות
- עובדים ומועמדים
- ספקים
- מצלמות אבטחה
- מתי להפריד מאגרים



מאגרי מידע (המשך)

מהי רמת האבטחה של המאגר?

רמת אבטחה גבוהה	רמת אבטחה בינונית	רמת אבטחה בסיסית
1. עומד בקריטריון רמת אבטחה בינונית 2. מכיל מידע על למעלה מ-100,000 אנשים או מספר בעלי ההרשאות גישה גדול מ-100	1. מטרה עיקרית: איסוף מידע לצורך מסירתו לאחר כעיסוק עיקרי כולל דיוור ישיר 2. גוף ציבורי 3. כולל: צנעת חייו האישיים של אדם, מידע רפואי, מידע גנטי, מידע על דעות פוליטיות, מידע על עבר פלילי, נתוני תקשורת, מידע ביומטרי, מידע על נכסיו של אדם וכו', הרגלי צריכה. *חריג: נשמר על מועסקים/ספקים או אין יותר מ-10 הרשאות גישה	1. על דרך השלילה; לא בינונית או גבוהה 2. מנוהל ע"י יחיד או תאגיד בבעלות יחיד-עד 3 הרשאות גישה

האם נדרשת הודעה לרשות או שיש חובת רישום?

- **מסירת הודעה לרשות: מאגר עם
מידע בעל רגישות מיוחדת על
100,000 איש ויותר**
- **רישום: גופים ציבוריים וארגונים
הסוחרים במידע**

**האם יש הסכמה ויידוע של
נושאי מידע?**

שלב ג': אחריות ארגונית

האם יש לארגון:

- ✓ ממונה על הגנת הפרטיות
- ✓ ממונה אבטחה
- ✓ מסמכי הגדרות מאגר*
- ✓ מיפוי מערכות ורשימת מצאי



תקנות הגנת הפרטיות (אבטחת מידע), תשע"ז-2017

- ✓ נוהל אבטחה
- ✓ אבטחה פיזית וסביבתית
- ✓ סקר סיכונים ומבחני חדירות
- ✓ ניהול הרשאות גישה
- ✓ זיהוי ואימות
- ✓ בקרה ותיעוד גישה (לוגים)
- ✓ גיבויים
- ✓ אבטחת תקשורת
- ✓ תיעוד אירועי אבטחה
- ✓ התקנים ניידים

אבטחת מידע (המשך)

תקנות הגנת הפרטיות (אבטחת מידע), תשע"ז-2017

✓ ניהול שרשרת אספקה – מיקור

חוץ

✓ ניהול כח אדם: סודיות, הרשאות

גישה, הדרכות

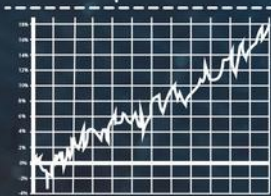
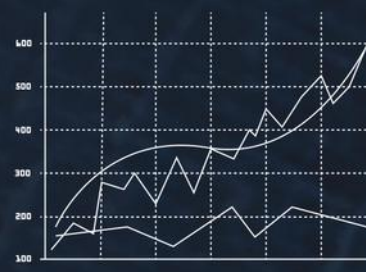
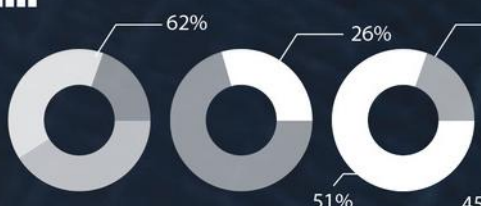
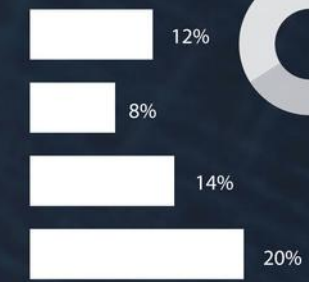
✓ ביקורת תקופתית

✓ תסקיר מצלמות

✓ זכויות והסכמות עובדים



GDPR





**עכשיו תסביר... איך
עושים את העבודה?**

סקר פרטיות - דוגמה



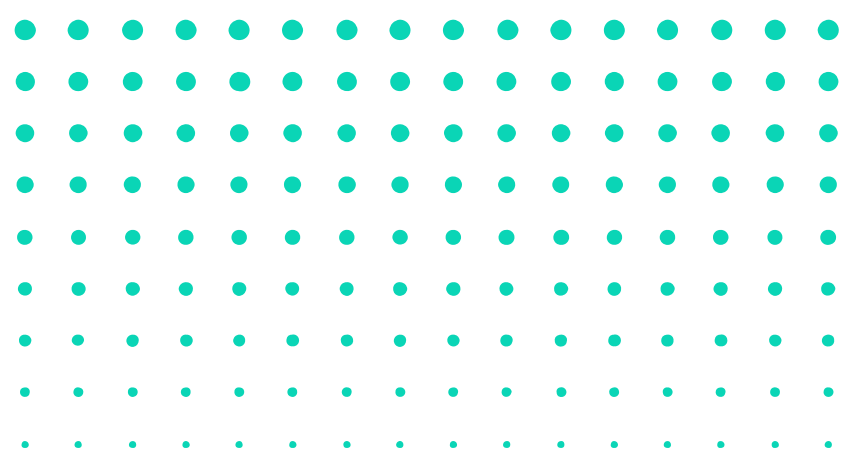
© עו"ד תני שפירא, MyEDPO

תמצית מנהלים

משפט קצר עליכם ועל החברה הנסקרת.
זכרו: המנהלים מכירים את החברה שלהם,
אבל לא את החוק או את ממצאי הסקר

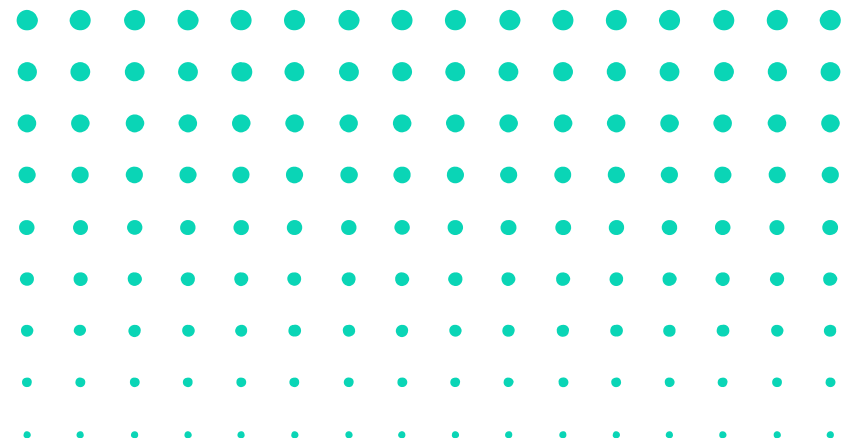


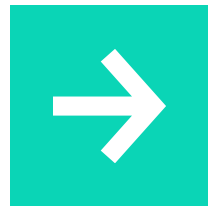
ממצאים עיקריים בסקר ולקחים מרכזיים
לביצוע עבור הארגון



רקע: אודות הארגון

כל מידע רלוונטי: מתי הוקם, מספר עובדים,
תחום פעילות, סוגי השירותים שהוא מציע, סוגי
הלקוחות, חברות אם/ בנות/ קשורות

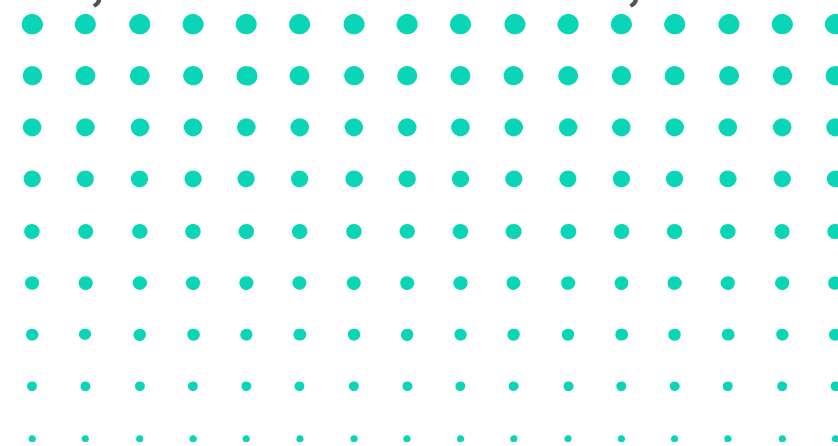


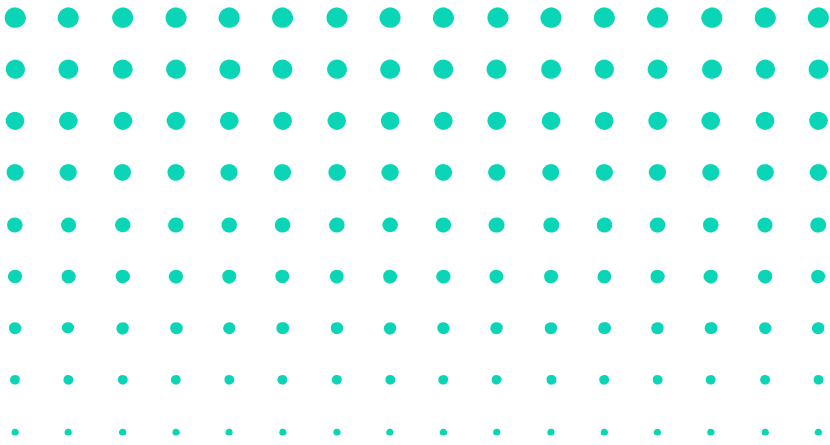


מסגרת נורמטיבית

אילו חוקים, תקנות, או גופים מנחים
רלוונטיים לחברה או לפעילות שלה?

1. מקורות כללים. כגון: חוק הגנת הפרטיות
2. מקורות ספציפיים לפי שירותים מוצעים. כגון: אנרגיה, פיננסים, הימורים, שירותים רפואיים, שירותי פרסום, סליקה
3. מקורות ספציפיים על גופים ספציפיים. כגון: בנקים, בתי חולים, גופים בטחוניים, משרדי עורכי דין





סיווג מאגרי מידע

מאגר 1 [שם מאגר]	[שם מאגר]	[שם מאגר]	[שם מאגר]
☐ איזה סוגי מידע יש במאגר ☐ סיווג רמת אבטחה (בסיסית, בינונית, גבוהה), כולל נימוק קצר ☐ האם הארגון בעל שליטה או מחזיק ☐ אם בעלים: (i) האם המאגר מחייב הודעה, (ii) האם קיים מסמך הגדרות מאגר ☐ מי המחזיקים העיקריים			



האם החברה עומדת בתקנות הגנת הפרטיות?

← [2#.....]

מה החובה
(בקצרה)

מה המצב
הנוכחי

הפער – מה
נדרש?

← [1# דוגמה: נוהל אבטחה]

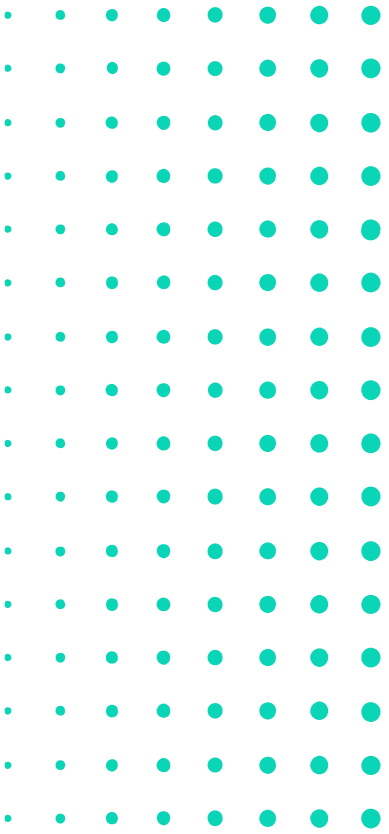
מה החובה (בקצרה)	כתיבה ואישור של נוהל אבטחת מידע
מה המצב הנוכחי	לא קיים
הפער – מה נדרש?	על החברה להכין נוהל ולהביאו לאישור ההנהלה

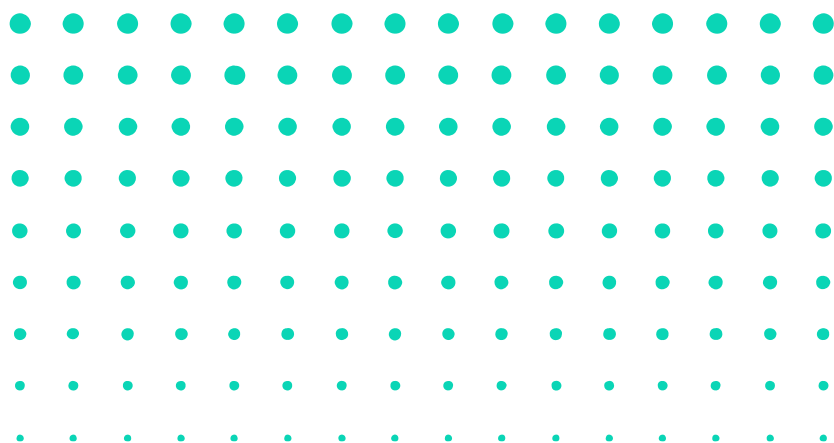
חשוב!

- (א) יש לבחון את הדרישות העיקריות שבתקנות הגנת הפרטיות (אבטחת מידע)
- (ב) בחינת מינוי DPO (אם קיימת חובה כזו)
- (ג) אופן היידוע של נושאי המידע
- (ד) תהליכי ניהול מיקור חוץ וכח אדם



GDPR, CCPA: האם חל ומדוע?





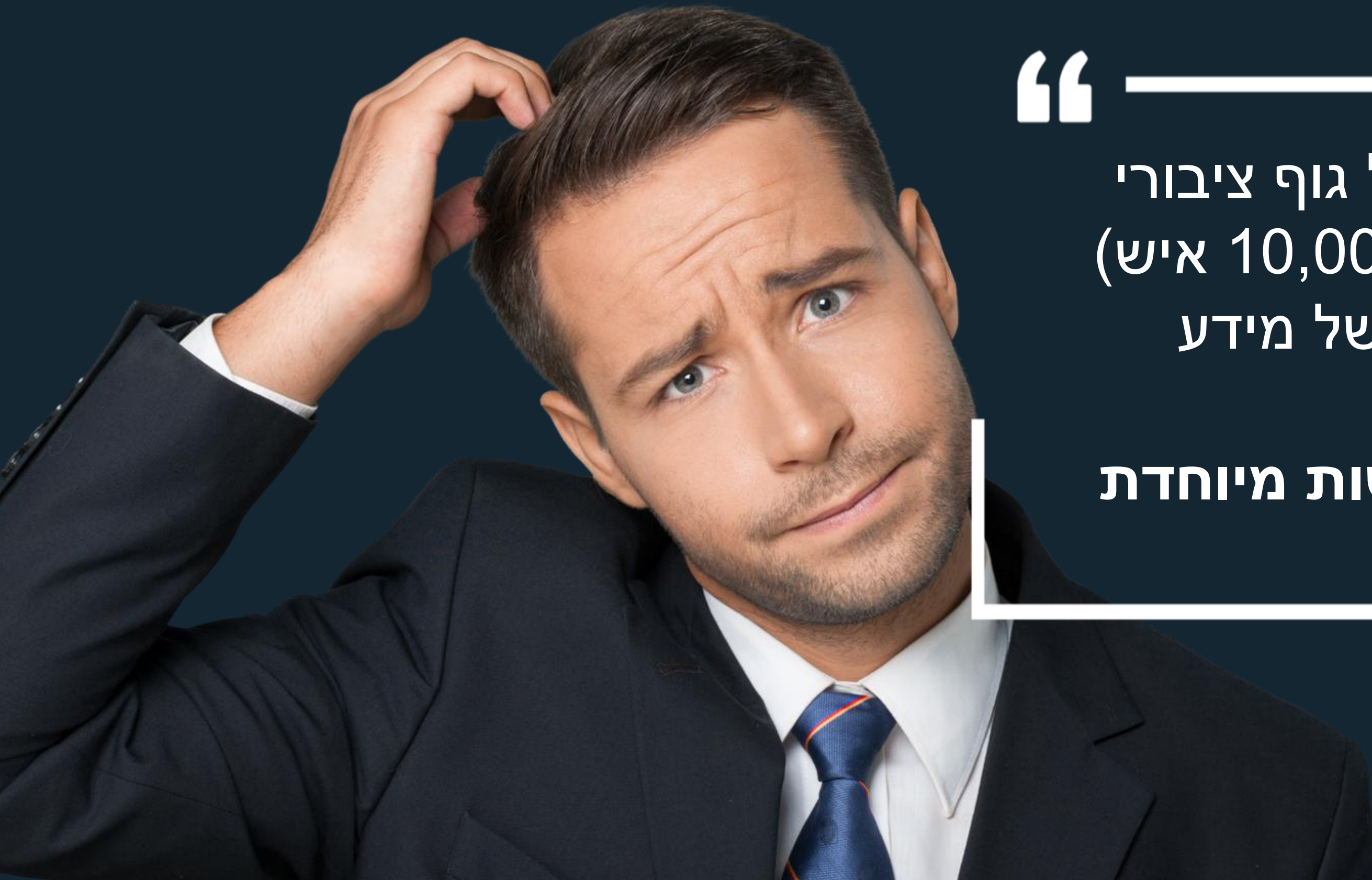
סיכום

מסקנות עיקריות:

מהן ההמלצות העיקריות ליישום עבור החברה.
הערה: ההמלצות יהיו לפי סדר הגיוני כלשהו
(עלות, קלות ביצוע, תועלת) בצורה פשוטה
וקריאה - עדיף במילים ולא בטבלה.



מתאי חובה למנות ממונה הגנת פרטיות (DPO)?



“

- ✓ גוף ציבורי / מאגר של גוף ציבורי
- ✓ גוף הסוחר במידע (10,000 איש)
- ✓ ניטור שוטף ושיטתי של מידע
- איש כדרך עיסוק
- ✓ עיבוד מידע בעל רגישות מיוחדת
- בהיקף נרחב

”



תפקידי ה-DPO

הבטחת קיום ההוראות וקידום השמירה על פרטיות ואבטחת מידע, כולל:

- סמכות מקצועית ומוקד ידע, ייעוץ להנהלה, הכנת תכנית הדרכה ופיקוח על הביצוע
- תכנית בקרה ווידוא ביצוע, דיווח להנהלה על ממצאים והצעות לתיקון
- וידוא קיום נוהל אבטחה ומסמך הגדרות, לאישור הנהלה
- טיפול בפניות ואיש קשר לרשות



ה-DPO בארגון:

✓ כישורים נדרשים - גילוי דעת הרשות

✓ תפקידים נוספים במקביל

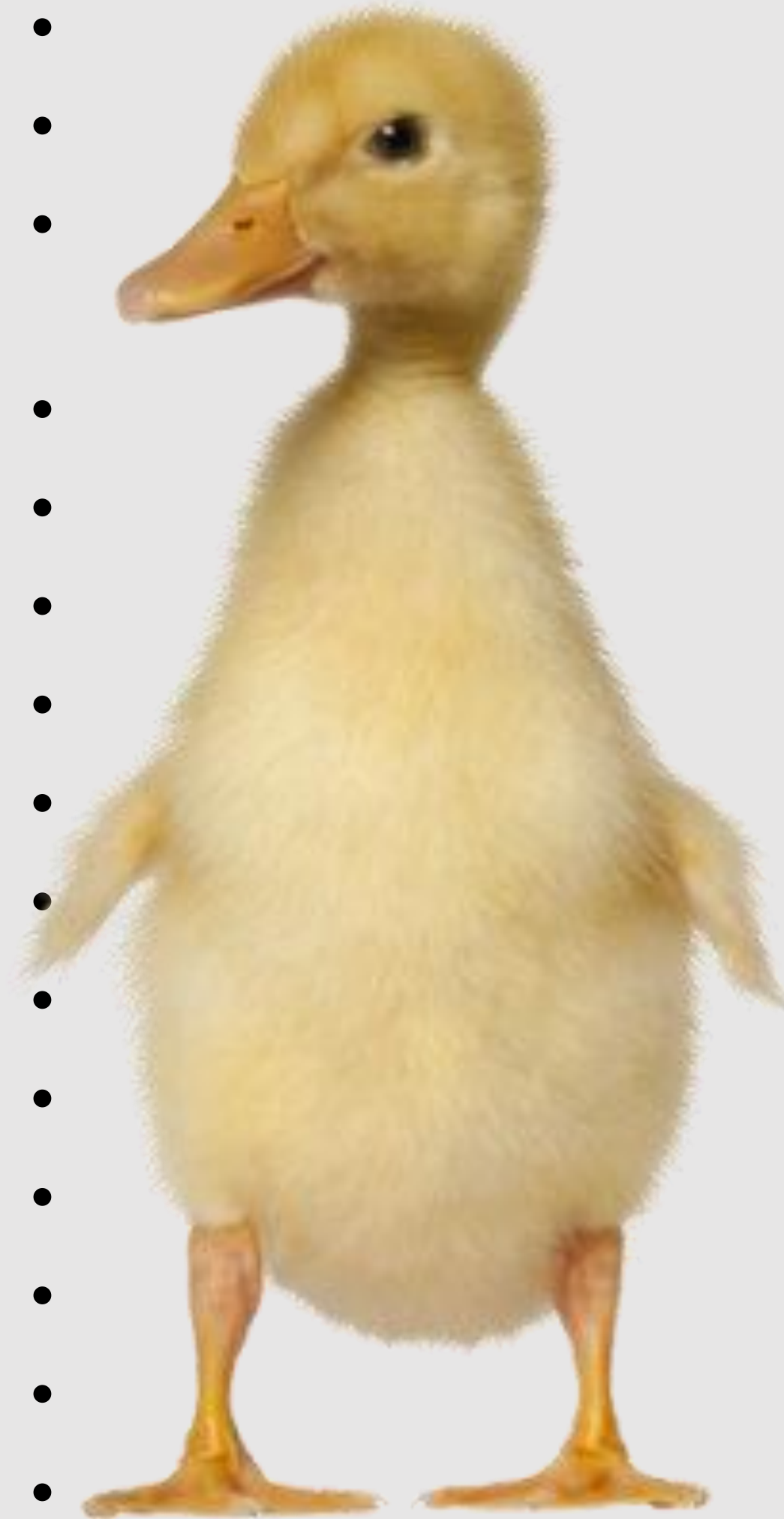
✓ DPO vs CISO

✓ למי לדווח?

כישורים נדרשים:



- ידע משפטי – היכרות עם החוק
- בעל יכולת עבודה בצוות וכושר שכנוע
- בעל יכולת עבודה והובלת תהליכים מול דרגים בכירים וכישורי ניהול
- היכרות עם טכנולוגית מידע (IT)
- הבנה בתחום אבטחת המידע
- ביקורת
- הבנה עסקית
- יכולת הדרכה
- היכרות עם GDPR וחוקים רלוונטיים נוספים
- טכנולוגיות מתפתחות
- עיצוב מוצר (PBD)
- זיהוי מגמות חדשות
- אתיקה
- התפתחויות רגולטוריות בעולם
- Data Governance





תודה רבה! מקווה שנהנתם

תני שפירא, עו"ד

DPO, MyEDPO

tani@myedpo.com